

ASSESSMENT AND APPROVAL

Clark Jason Ngo

ISEC 510 The Senior Manager and Information Security

February 25, 2018

Scott Buchanan

City University of Seattle

Abstract

This research uses the report of Center for Internet Security's (CIS) Oracle MySQL Community Server 5.7, a publicly available security checklist that is also hosted by National Vulnerability Database and National Checklist Program Repository. The research would first discuss information system security. The research would then verify report from CIS and from release notes from MySQL. The research would then evaluate the both the report and release notes and suggest if the application is approved to operate at a proposed level of trust. The research is focused and limited to checks on logs and audits, authentication, network, and replication of MySQL Server 5.7. Work environment is set to personal and private network. The research includes the following documents: ATO Letter Extensible, Configuration Management Plan Extensible, Relevant Change Report, Risk Assessment, SAPT Letter Ext, and Vulnerability and Penetration Test Report.

Assessment and Approval

Organizations increasingly depend on information systems on their day-to-day for important business operations. A simple assessment of security is to create checklists, to monitor whether a certain item passed or failed, and from that, create paperwork for inspection and audits (National Institute of Standards and Technology, 2010). Logs and audit are can used to check for error messages and vulnerabilities. Authentication can be strengthened by implementing password complexity. Network can be added with SSL encryption security to add defensive layer. Cleaning up user data and privileges in replication traffic for master-client server communication protection. These are some of the checks that can be done with querying and executing SQL statements, configuring the MySQL configuration file or installing additional tools like SSL, third-party audit software and other monitoring tools.

Recommendations by Center for Internet Security for MySQL 5.7

A report for Oracle MySQL Community Server 5.7 by Center for Internet Security, a nonprofit organization uses crowdsourcing model to identify and refine effective security measures, made recommendations on the following: (1) operating system level configuration, (2) installation and planning, (3) file system permissions, (4) general, (5) MySQL permissions, (6) auditing and logging, (7) authentication, (8) network, and (9) replication (Center for Internet Security, 2015). The CIS based the checklist on Oracle's MySQL 5.7 Reference Manual and Oracle's release notes documentation for MySQL 5.7. Example for a release note: (1) audit log notes, (2) configuration notes, (3) depreciation and removal notes, (4) performance schema notes, (5) pluggable authentication, (6) security notes, (7) test suite notes, (8) functionality added or changed, and (9) bugs fixed (Changes in MySQL 5.7.21 (2018-01-15, general availability), 2018).

Auditing and logging for information systems

Logs play a crucial role for security when there is a suspected cyberattack. A manual review of logs is painstaking for a security personnel and must use log review tools to extract information and analyze them. It is noted that log should use a WORM (write once read many) storage technology and encryption to avoid corruption and losing log data. Also, logs should have a standardized format for ease of maintenance, access and comparison. Before analyzing the logs, establishing a benchmark is needed to understand what is deemed normal to the organization's information system protection and vulnerabilities. After logging, an audit is necessary to check for compliance, especially for compliance-centric organizations. Audit can also be done by a third-party security consultant (Anderson, 2014). With the use of log data along with external intelligence, organizations can formulate on what external cyber threats are likely to attack the organization's system (Liska, 2015).

With the report from CIS as guide, the author ran the checks in his own system in a Windows 10 operating system and MySQLServer version 5.7.2.1 in 64-bit architecture. Used the following audit and log checks on his system: (1) ensure "log_error" is not empty, (2) ensure log files are stored on a non-system partition, (3) ensure "log_error_verbosity" is not set to "1", and (4) ensure audit logging is enabled (Center for Internet Security, 2015).

Ensure "log_error" is not empty

Error logs contains data on events when mysqld starts or stops. It also shows when a table needs to be assessed or repaired. It must generate a "value". The reason for enabling error logging is it helps increase the ability to detect malicious attempts against MySQL and other vital messages. Without error logging, even a connection error will be unknown to the user. To audit, execute SQL statement: SHOW variables LIKE 'log_error'; (Center for Internet Security,

2015). In the figure below, the author's system returned a "value". Corrective if otherwise, (1) open the MySQL configuration file (my.cnf or my.ini) and (2) set the "log-error" option to the path for the error log.

```
mysql> SHOW variables LIKE 'log_error';
+-----+-----+
| Variable_name | Value                |
+-----+-----+
| log_error     | .\DJ-JASON-CLARK.err |
+-----+-----+
1 row in set (0.10 sec)
```

Figure 1: Log error with value

Ensure log files are stored on a non-system partition

Log files of MySQL can be stored anywhere in the filesystem and set using the MySQL configuration. Also, it is a best practice is to ensure that the logs in the filesystem are not cluttered with other logs such as application logs. Must ensure that the value returned is does not indicate that it is in the root “(‘)”, “/var”, or “/usr”. The reason for this is that partitioning will decrease the likelihood of denial of service if the available disk space to the operating system is depleted. To audit, execute SQL statement: `SELECT @@global.log_bin_basename;` (Center for Internet Security, 2015). In the figure below, the author's system returned a “null”. Corrective if otherwise, (1) open the MySQL configuration file (my.cnf) and (2) locate the “log-bin” entry and set it to a file not on root “(‘)”, “/var”, or “/usr”.

```
mysql> SELECT @@global.log_bin_basename;
+-----+
| @@global.log_bin_basename |
+-----+
| NULL                      |
+-----+
1 row in set (0.00 sec)
```

Figure 2: Log files in non-system partition

Ensure “log_error_verbosity” is not set to “1”

This check would provide additional information to what functionalities of MySQL log has or enabled on error messages. Value of 1 enables logging of error messages. Value of 2 enables both logging of error and warning messages. Value of 3 enables logging of error, warning, and note messages. This helps detect malicious behavior by logging communication errors and aborted connections. To audit, execute SQL statement: SHOW GLOBAL VARIABLES LIKE 'log_error_verbosity'; (Center for Internet Security, 2015). (Center for Internet Security, 2015). In the figure below, the author’s system returned a “3”. Corrective if otherwise, (1) open the MySQL configuration file (my.cnf) and (2) ensure “log_error_verbosity = 2” (or 3).

```
mysql> SHOW GLOBAL VARIABLES LIKE 'log_error_verbosity';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| log_error_verbosity | 3     |
+-----+-----+
1 row in set (0.16 sec)
```

Figure 3: Log error verbosity

Ensure audit logging is enabled

Enabling audit logging is crucial for production environment for interactive user sessions and application sessions. With audit logging, it helps identification on who changed what and when. It can help to identify what an attacker has done and can be even use as evidence in investigations (Center for Internet Security, 2015). To audit, execute SQL statement: SELECT NAME FROM performance_schema.setup_instruments WHERE NAME LIKE '%/alog/%'; (6.5.5 MySQL Enterprise Audit, 2018). In the figures below, the author’s system returned an empty set. Instead the author used the The General Query Log

(<https://dev.mysql.com/doc/refman/5.7/en/query-log.html>) by SQL statement: SET GLOBAL general_log = 'ON' ; then followed with another SQL statement: CREATE USER 'user1'@'localhost' IDENTIFIED BY PASSWORD 'not-so-secret'; (5.4.3 The General Query Log, 2018). Also, ensured that the latter SQL statement was logged. The log's path in Windows 10 can be found using Services application, looking for the MySQL running, and right-click properties. The log in the author's system was located in: C:\ProgramData\MySQL\MySQL Server 5.7\Data\DJ-JASON-CLARK.log, see below Figure 8. Other corrective is to acquire a third-party MySQL logging solution such as MySQL Enterprise Audit (<https://www.mysql.com/products/enterprise/audit.html>), MariaDB Audit Plugin for MySQL (<https://mariadb.com/kb/en/library/mariadb-audit-plugin-log-settings/>), or McAfee MySQL Audit (<https://github.com/mcafee/mysql-audit/wiki>).

```
mysql> SELECT NAME FROM performance_schema.setup_instruments
-> WHERE NAME LIKE '%alog%';
Empty set (0.23 sec)
```

Figure 4: Audit log 1

```
mysql> show global status like 'AUDIT_version';
Empty set (0.03 sec)
```

Figure 5: Audit log 2

```
mysql> show plugins;
```

Name	Status	Type	Library	License
binlog	ACTIVE	STORAGE ENGINE	NULL	GPL
mysql_native_password	ACTIVE	AUTHENTICATION	NULL	GPL
sha256_password	ACTIVE	AUTHENTICATION	NULL	GPL
CSV	ACTIVE	STORAGE ENGINE	NULL	GPL
MEMORY	ACTIVE	STORAGE ENGINE	NULL	GPL
InnoDB	ACTIVE	STORAGE ENGINE	NULL	GPL
INNODB_TRX	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_LOCKS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_LOCK_WAITS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMP	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMP_RESET	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMPMEM	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMPMEM_RESET	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMP_PER_INDEX	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_CMP_PER_INDEX_RESET	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_BUFFER_PAGE	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_BUFFER_PAGE_LRU	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_BUFFER_POOL_STATS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_TEMP_TABLE_INFO	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_METRICS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_DEFAULT_STOPWORD	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_DELETED	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_BEING_DELETED	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_CONFIG	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_INDEX_CACHE	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_FT_INDEX_TABLE	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_TABLES	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_TABLESTATS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_INDEXES	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_COLUMNS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_FIELDS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_FOREIGN	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_FOREIGN_COLS	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_TABLESPACES	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_DATAFILES	ACTIVE	INFORMATION SCHEMA	NULL	GPL
INNODB_SYS_VIRTUAL	ACTIVE	INFORMATION SCHEMA	NULL	GPL
MyISAM	ACTIVE	STORAGE ENGINE	NULL	GPL
MRG_MYISAM	ACTIVE	STORAGE ENGINE	NULL	GPL
PERFORMANCE_SCHEMA	ACTIVE	STORAGE ENGINE	NULL	GPL
ARCHIVE	ACTIVE	STORAGE ENGINE	NULL	GPL
BLACKHOLE	ACTIVE	STORAGE ENGINE	NULL	GPL
FEDERATED	DISABLED	STORAGE ENGINE	NULL	GPL
partition	ACTIVE	STORAGE ENGINE	NULL	GPL
ngram	ACTIVE	FTPARSER	NULL	GPL

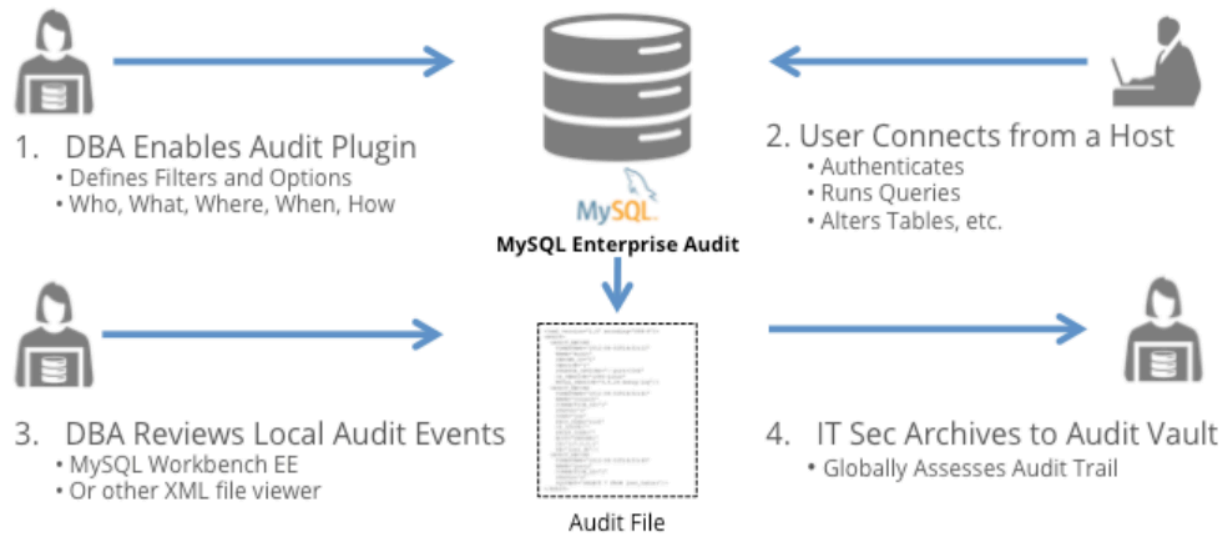
```
44 rows in set (0.08 sec)
```

Figure 6: No audit log plugins

```
mysql> SET GLOBAL general_log = 'ON';
Query OK, 0 rows affected (0.02 sec)
```

Figure 7: General log query

```
C:\Program Files\MySQL\MySQL Server 5.7\bin\mysqld.exe, Version: 5.7.21-log (MySQL Community Server (GPL)). started with:
TCP Port: 3306, Named Pipe: MySQL
Time      Id Command      Argument
2018-02-21T19:18:31.412327Z  28 Query CREATE USER 'user1'@'localhost' IDENTIFIED BY PASSWORD 'not-so-secret'
2018-02-21T20:00:40.585570Z  28 Query SET GLOBAL general_log = 'ON'
2018-02-21T20:24:12.054249Z  28 Query show variables where variable_name = 'datadir'
```

Figure 8: General log in the system**Figure 9: MySQL Enterprise Audit process** (MySQL Enterprise Audit, 2018)

Authentication for information system

Authentication is a process which the credentials provided by the user or machine is matched with the database of authorized users in a local operating system or in an authentication server. Authentication is then preceded by authorization which are granted by administrator to users or machines. An authentication that is commonly used in both private and public networks is password-based authentication. Password-based authentication is created with login IDs (or user names) and passwords. It is assumed that possessing the knowledge of both login ID and password makes the user authentic. The problem with password-based authentication is the security strength of the authentication relative to the password policy implemented on the network, as it is assumed that users follow the bare minimum password requirement (Rouse, 2015).

With the report from CIS as guide, the author ran the checks in his own system in a Windows 10 operating system and MySQLServer version 5.7.2.1 in 64-bit architecture. Used the

following authentication checks on his system: (1) ensure passwords are not stored in the global configuration, (2) ensure 'sql_mode' contains 'NO_AUTO_CREATE_USER', (3) ensure passwords are set for all MySQL accounts, (4) ensure 'default_password_lifetime' is less than or equal to '90', (5) ensure password complexity is in place, (6) ensure no users have wildcard hostnames, and (7) ensure no anonymous accounts exist (Center for Internet Security, 2015).

Ensure passwords are not stored in the global configuration

The [client] section of MySQL configuration file allows creation of a user and password to be set. The check is important because allowing user and password in the configuration file impacts confidentiality of the user's password negatively. To audit, open MySQL configuration file and examine [client] section and must not have any password stored. (Center for Internet Security, 2015). No password was set in the author's system, see Figure 10 below. If password was set in configuration file, use mysql_config_editor to store passwords in encrypted form in .mylogin.cnf.

```
[client]

# pipe=
# socket=0.0
port=3306
```

Figure 10: [client] section of MySQL configuration file

Ensure 'sql_mode' contains 'NO_AUTO_CREATE_USER'

The "no_auto_create_user" is an option to prevent auto creation of user when authentication information is not provided. To audit, must check for that both SQL statements: SELECT @@global.sql_mode; and SELECT @@session.sql_mode; contains "NO_AUTO_CREATE_USER" (Center for Internet Security, 2015). The author's system return a "NO_AUTO_CREATE_USER" value, see below Figure 11. Corrective if otherwise, open

MySQL configuration file, then set “NO_AUTO_CREATE_USER” in sql_mode setting in the [mysqld] area.

```
mysql> SELECT @@global.sql_mode;
+-----+
| @@global.sql_mode |
+-----+
| STRICT_TRANS_TABLES,NO_AUTO_CREATE_USER,NO_ENGINE_SUBSTITUTION |
+-----+
1 row in set (0.88 sec)
```

Figure 11: No auto create user in global

```
mysql> SELECT @@session.sql_mode;
+-----+
| @@session.sql_mode |
+-----+
| STRICT_TRANS_TABLES,NO_AUTO_CREATE_USER,NO_ENGINE_SUBSTITUTION |
+-----+
1 row in set (0.00 sec)
```

Figure 12: No auto create user in session

Ensure passwords are set for all MySQL accounts

A user can create a blank password. Having a blank password is risky as anyone can just assume the user’s identity, enter the user’s loginID and connect to the server. This bypasses authentication, which is bad. To audit, execute the SQL query: SELECT User,host FROM mysql.user WHERE authentication_string=""; (Center for Internet Security, 2015). Must generate “no rows”, meaning no user has a blank password. The author’s system returned no rows. Corrective if otherwise, execute SQL statement: SET PASSWORD FOR <user>@'<host>' = '<clear password>'.

```
mysql> SELECT User,host
-> FROM mysql.user
-> WHERE authentication_string='';
Empty set (0.04 sec)
```

Figure 13: Users with blank passwords

Ensure 'default_password_lifetime' is less than or equal to '90'

Changing password lifetime to 90 days decreases the time available for the attacker to compromise the password thus decreases the likelihood of getting attacked. To audit, execute SQL statement: `SHOW VARIABLES LIKE 'default_password_lifetime';` (Center for Internet Security, 2015). The value must return a 90 or more. The author's system returned a 0. To correct, execute SQL statement: `SET GLOBAL default_password_lifetime=90.`

```
mysql> SHOW VARIABLES LIKE 'default_password_lifetime';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| default_password_lifetime | 0     |
+-----+-----+
1 row in set (0.05 sec)
```

Figure 14: Default password lifetime with 0 value

```
mysql> SET GLOBAL default_password_lifetime=90;
Query OK, 0 rows affected (0.00 sec)

mysql> SHOW VARIABLES LIKE 'default_password_lifetime';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| default_password_lifetime | 90    |
+-----+-----+
1 row in set (0.00 sec)
```

Figure 15: Setting default password lifetime to 90

Ensure password complexity is in place

Password complexity adds security strength to authentications and includes by adding or increasing length, case, numbers and special characters. The more complex the password, the harder for attackers to brute force to obtain the password. Weak passwords are easily run in a password dictionary. To audit, execute SQL statement: `SHOW VARIABLES LIKE 'validate_password%';` (Center for Internet Security, 2015). The SQL statement should return the following: “`validate_password_length`” should be 14 or more, “`validate_password_mixed case_count`” should be 1 or more, “`validate_password_number_count`” should be 1 or more,

“validate_password_special_char_count” should be 1 or more, and “validate_password_policy” should be “MEDIUM” or “STRONG”. The author system’s return an empty set. To correct:

```
plugin-load=validate_password.so
```

```
validate-password=FORCE_PLUS_PERMANENT
```

```
validate_password_length=14
```

```
validate_password_mixed_case_count=1
```

```
validate_password_number_count=1
```

```
validate_password_special_char_count=1
```

```
validate_password_policy=MEDIUM
```

```
mysql> SHOW VARIABLES LIKE 'validate_password%';  
Empty set (0.00 sec)
```

Figure 16: Check for password complexity

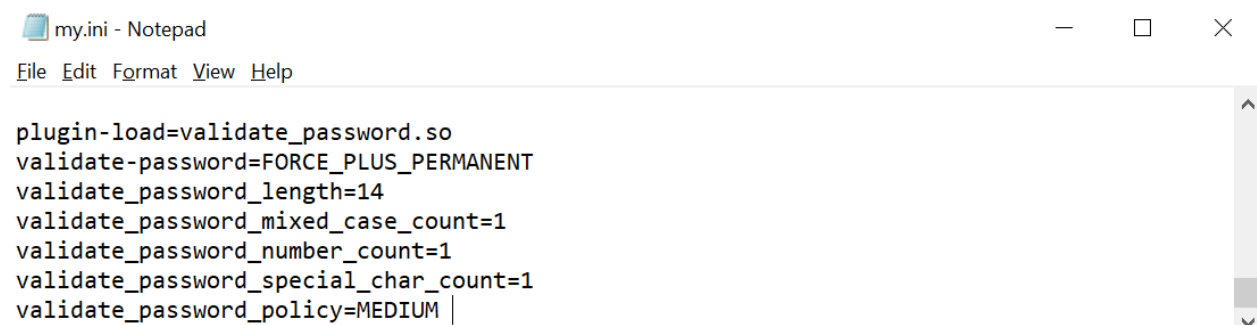


Figure 17: Implement password complexity

Ensure no users have wildcard hostnames

Users with wildcard hostname (%) are granted permission to any location. It is best to avoid creating wildcard hostnames and instead create users and give them specific location from which a given user may connect to and interact with the database. To audit, execute SQL query: `SELECT user, host FROM mysql.user WHERE host = '%';` (Center for Internet Security, 2015).

The author's system returned a user with a host. To correct, choose the user/s and either "ALTER" or "DROP" the user.

```
mysql> SELECT user, host FROM mysql.user WHERE host = '%';
+-----+-----+
| user   | host |
+-----+-----+
| clarkngo | %   |
+-----+-----+
1 row in set (0.03 sec)
```

Figure 18: Wildcard hostname

```
mysql> UPDATE mysql.user SET host = '3306' WHERE user = 'clarkngo';
Query OK, 1 row affected (0.02 sec)
Rows matched: 1  Changed: 1  Warnings: 0

mysql> SELECT user, host FROM mysql.user WHERE host = '3306';
+-----+-----+
| user   | host |
+-----+-----+
| clarkngo | 3306 |
+-----+-----+
1 row in set (0.00 sec)
```

Figure 19: Change wildcard hostname

Ensure no anonymous accounts exist

Users can have an anonymous (empty or blank) username. These anonymous usernames have no passwords can any other user can use that anonymous username to connect to the MySQL server. Removal of these anonymous accounts ensures only identified and trusted users can access MySQL server. To audit, execute SQL query: `SELECT user,host FROM mysql.user WHERE user = ''`; (Center for Internet Security, 2015). The author's system return empty set. Corrective if otherwise, "DROP" anonymous user for each instance in the above SQL query.

```
mysql> SELECT user,host FROM mysql.user WHERE user = '';
Empty set (0.00 sec)
```

Figure 20: No anonymous accounts

Network connection to MySQL server

The network connection plays an important role for communication between user and MySQL server. Unsecure network connections very vulnerable to attacks. The following are checks for network connection security. The following checks are made but no corrective action was done. These checks are: (1) ensure 'have_ssl' is set to 'YES', and (2) ensure 'ssl_type' is set to 'ANY', 'X509', or 'SPECIFIED' for all remote users.

Ensure 'have_ssl' is set to 'YES'

To avoid malicious attackers peeking inside your system, it is best to use SLL/TLS for all network traffic when using untrusted networks. To audit, SHOW variables WHERE variable_name = 'have_ssl'; (Center for Internet Security, 2015). The value should return “YES”. The author’s system returned “DISABLED”. A corrective action for this is enable SSL or building MySQL with OpenSSL or YaSSL.

```
mysql> SHOW variables WHERE variable_name = 'have_ssl';
+-----+-----+
| Variable_name | Value   |
+-----+-----+
| have_ssl      | DISABLED |
+-----+-----+
1 row in set (0.05 sec)
```

Figure 21: No SSL

Ensure 'ssl_type' is set to 'ANY', 'X509', or 'SPECIFIED' for all remote users

SSL/TLS should be configured per user. This further prevents eavesdropping of malicious attackers. To audit, execute SQL statement: SELECT user, host, ssl_type FROM mysql.user WHERE NOT HOST IN ('::1', '127.0.0.1', 'localhost'); (Center for Internet Security, 2015). It must return “ANY”, “X509”, or “SPECIFIED”. The author’s system return no SSL type. To correct this, execute SQL statement in this format: GRANT USAGE ON *.* TO 'my_user'@'app1.example.com' REQUIRE SSL;.

```
mysql> SELECT user, host, ssl_type FROM mysql.user
-> WHERE NOT HOST IN ('::1', '127.0.0.1', 'localhost');
+-----+-----+-----+
| user      | host | ssl_type |
+-----+-----+-----+
| clarkngo  | 3306 |          |
+-----+-----+-----+
1 row in set (0.02 sec)
```

Figure 21: No ssl_type

Replication

Checking for replication status lets you monitor performance and security vulnerabilities (Checking replication status, 2005). Microsoft SQL Server Management Studio have the following tools to monitor replication: (1) view snapshot agent status, (2) view log reader agent status, and (3) view synchronization status (How to: monitor replication agents from Management Studio (SQL Server Management Studio), 2018). The checks done on the system are: (1) ensure replication traffic is secured, (2) ensure 'MASTER_SSL_VERIFY_SERVER_CERT' is set to 'YES' or '1', (3) ensure 'master_info_repository' is set to 'TABLE', (4) ensure 'super_priv' is not set to 'Y' for replication users, and (5) ensure no replication users have wildcard hostnames (Center for Internet Security, 2015).

Ensure replication traffic is secured

Replication traffic between servers must be secured. During replication transfers, passwords could leak. To audit, check if using: a private network, a VPN, SSL/TLS or a SSH Tunnel. The author's system is using a private network. Corrective if otherwise, secure by using the private network, a VPN, SSL/TLS or a SSH Tunnel (Center for Internet Security, 2015).

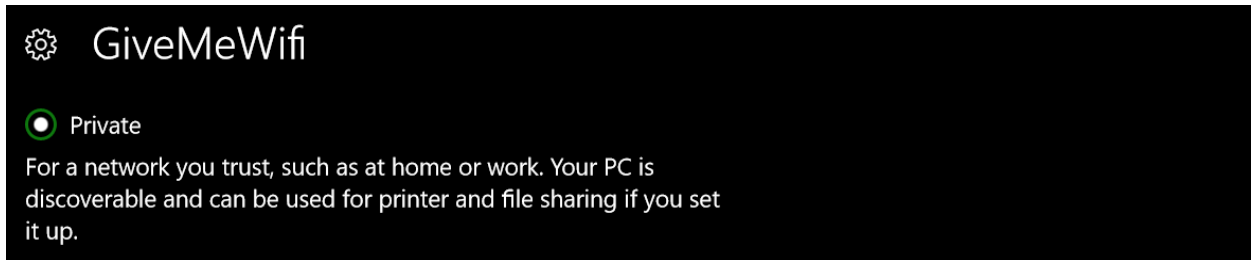


Figure 22: Private network

Ensure 'MASTER_SSL_VERIFY_SERVER_CERT' Is Set to 'YES' or '1'

'MASTER_SSL_VERIFY_SERVER_CERT' checks whether the slave should verify the master's certificate or not. The slave should verify the master's certificate to authenticate the master before continuing the connection. To audit, execute sql query: `SELECT ssl_verify_server_cert FROM mysql.slave_master_info;` (Center for Internet Security, 2015). It must have a value of 1. The author's system having no SSL, return empty set. To correct: "STOP SLAVE; -- required if replication was already running" then "CHANGE MASTER TO MASTER_SSL_VERIFY_SERVER_CERT=1; START SLAVE;".

```
mysql> SELECT ssl_verify_server_cert FROM mysql.slave_master_info;
Empty set (0.01 sec)
```

Figure 23: No SSL for slave-master check

Ensure 'master_info_repository' is set to 'TABLE'

The 'master_info_repository' determines where slave logs master status and connection information. Password is stored in the master info repository that is a plaintext file. Storing the password in TABLE master info is a safer. To audit, execute SQL query: `SHOW GLOBAL VARIABLES LIKE 'master_info_repository';` (Center for Internet Security, 2015). It must generate a value of "TABLE" instead of "FILE". The author's system generated the value "FILE". Author's system has no master-slave client connection. To correct: open MySQL configuration file and locate and set the master_info_repositor value to "TABLE".

```
mysql> SHOW GLOBAL VARIABLES LIKE 'master_info_repository';
+-----+-----+
| Variable_name | Value |
+-----+-----+
| master_info_repository | FILE |
+-----+-----+
1 row in set (0.05 sec)
```

Figure 24: Master info repository value

Ensure 'super_priv' is not set to 'Y' for replication users

The “SUPER” privilege ('super_priv') located in the “mysql.user” table has functions like “CHANGE”, “MASTER TO”, “KILL”, “mysqladmin kill”, “PURGE BINARY LOGS”, “SET GLOBAL”, “mysqladmin debug”, and other logging controls. A user having the “SUPER” privilege allows the user to view and terminate currently executing SQL statements, even for password management. If the attacker exploits and gains the “SUPER” privilege, they can disable, alter or destroy logging data. To audit, execute SQL query: SELECT user, host FROM mysql.user WHERE user='repl' and Super_priv = 'Y'; (Center for Internet Security, 2015). It must not retrieve row. The author’s system did not retrieve a row from the query. Corrective if otherwise, enumerate replication users from audit and issue SQL statement: REVOKE SUPER ON *.* FROM 'repl';.

```
mysql> SELECT user, host FROM mysql.user WHERE user='repl' and Super_priv = 'Y';
Empty set (0.00 sec)
```

Figure 25: Replication check for users with SUPER privilege

Ensure no replication users have wildcard hostnames

MySQL allows granting of permissions to wildcard hostnames. Wildcard hostnames should be avoided and create or modify to users and give them specific location from which a given user may connect to and interact with the database. To audit, execute SQL query: SELECT user, host FROM mysql.user WHERE user='repl' AND host = '%'; (Center for Internet Security,

2015). It must not retrieve any row. The author's system did not retrieve a row from the query. Corrective if otherwise, enumerate replication users from audit and either "ALTER" the user's host or "DROP" the uses.

```
mysql> SELECT user, host FROM mysql.user WHERE user='repl' AND host = '%';  
Empty set (0.00 sec)
```

Figure 26: Replication check for wildcard hostnames

Conclusion

The following checks are made for a single work environment using MySQL as the information system on both the application-side and the user-side. The research would prepare or secure users that uses MySQL while connected to a private or public network. The assessment is imperative to check for standard logging of MySQL and enabling additional logging functions. Also, checking for authentication vulnerabilities. Network checks are important to avoid other users with malicious intent to peek into your network. Always implement SSL/TLS to encrypt. Securing one-way transfer is necessary. Securing replication traffic adds a defensive layer. Both are deemed important in securing information systems. The assessment made on the author's system is favorable and passed most of the crucial checks. It is therefore deemed to be able to operate at a level of trust.

References

5.4.3 *The General Query Log*. (2018). Retrieved from MySQL:

<https://dev.mysql.com/doc/refman/5.7/en/query-log.html>

6.5.5 *MySQL Enterprise Audit*. (2018). Retrieved from MySQL:

<https://dev.mysql.com/doc/refman/5.7/en/audit-log.html>

Anderson, K. (2014). *The frugal CISO: Using innovation and smart approaches to maximize your security posture* (1 ed.). Philadelphia, PA: Auerbach Publications.

Center for Internet Security. (2015, December 29). *CIS Oracle MySQL Community Server 5.7*. Retrieved from

https://cta-service-cms2.hubspot.com/ctas/v2/public/cs/c/?cta_guid=5b762977-542d-49c1-b192-56529e7fdd96&placement_guid=48c2c2be-1a3d-4b36-ac18-fd6668b38edc&portal_id=2101505&redirect_url=APefjpEyAgSSI-Xv0eb5EZkmehTDM3IXLe-TIDqg1Y7UJUkHAZ3ULueflnSObeIk2wER

Changes in MySQL 5.7.21 (2018-01-15, general availability). (2018, January 15). Retrieved from MySQL:

<https://dev.mysql.com/doc/relnotes/mysql/5.7/en/news-5-7-21.html>

Checking replication status. (2005, July 17). Retrieved from Microsoft:

[https://technet.microsoft.com/en-us/library/bb125033\(v=exchg.65\).aspx](https://technet.microsoft.com/en-us/library/bb125033(v=exchg.65).aspx)

How to: monitor replication agents from Management Studio (SQL Server Management Studio). (2018).

Retrieved from Microsoft:

[https://technet.microsoft.com/en-us/library/ms152763\(v=sql.105\).aspx](https://technet.microsoft.com/en-us/library/ms152763(v=sql.105).aspx)

Liska, A. (2015). *Building an intelligence-led security program*. Waltham: Syngress. Retrieved January 20,

2018, from <https://cityuseattle.skillport.com/skillportfe/main.action?assetid=78134>

MySQL Enterprise Audit. (2018). Retrieved from MySQL:

<https://www.mysql.com/products/enterprise/audit.html>

National Institute of Standards and Technology. (2010, June). *Guide for assessing the security controls in federal information systems and organizations*. Gaithersburg: National Institute of Standards and Technology. Retrieved from

https://clearwatercompliance.com/wp-content/uploads/sp800-53A-rev1-final_Guide_for_Assessing_the_Security_Controls_in_Federal_Information_Systems_and_Organizations-Building_Effective_Security_Assessment_Plans.pdf

Rouse, M. (2015, February). *authentication*. Retrieved from SearchSecurity:

<http://searchsecurity.techtarget.com/definition/authentication>